

TRƯỜNG ĐẠI HỌC FPT

Viện Đào tạo Sau Đại học

**Kiến trúc Nhận thức Hai tầng cho
Phát hiện và Phản hồi Mỗi đe dọa
Tự động sử dụng AI Tác tử**

Đề cương Luận văn Thạc sĩ

Học viên: Nguyễn Đức Bình

MSSV: MSE13183

Giảng viên hướng dẫn: Bùi Văn Hiệu

Hà Nội, 2026

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh (SOC) đang phải đối mặt với một “Nghịch lý Dữ liệu lớn” nghiêm trọng: khối lượng khổng lồ các sự kiện mạng phát sinh mỗi giây dẫn đến tình trạng quá tải cảnh báo, với phần lớn trong số đó là dương tính giả. Các hệ thống Phát hiện Xâm nhập (IDS) và Quản lý Sự kiện An ninh (SIEM) truyền thống thường phân tích luồng dữ liệu một cách đơn lẻ, qua đó làm suy giảm đáng kể khả năng nhận diện các chiến dịch tấn công có chủ đích tinh vi (APT). Gần đây, việc ứng dụng trực tiếp các Mô hình Ngôn ngữ Lớn (LLM) vào việc phân tích log đã được thử nghiệm; tuy nhiên, hướng đi này lại mở ra hai lỗ hổng rủi ro lớn: độ trễ suy luận quá cao không thể đáp ứng được tốc độ của luồng dữ liệu thời gian thực, và nguy cơ hệ thống LLM bị thao túng bởi các đòn tấn công Prompt Injection ẩn giấu ngay bên trong dữ liệu log độc hại.

Để giải quyết triệt để những thách thức này, nghiên cứu đề xuất một kiến trúc nhận thức (cognitive architecture) kết hợp giữa một Động cơ Quy tắc (Rule Engine) xác định và một Mô hình Ngôn ngữ Lớn. Thông qua phương pháp tiếp cận hai tầng, hệ thống được kỳ vọng sẽ sàng lọc lượng lớn nhiễu ở tốc độ cao (Tầng 1), đồng thời bảo lưu năng lực suy luận sâu — được vận hành bởi AI Tác tử dựa trên LangGraph cùng cơ chế Dual-RAG (tích hợp MITRE ATT&CK và ISO 27001) — để xử lý các mối đe dọa phức tạp và khó đoán (Tầng 2). Bên cạnh đó, một cơ chế Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation) cũng được giới thiệu nhằm vô hiệu hóa các nỗ lực chèn mã độc vào prompt mà không làm mất đi thông tin payload quan trọng cần thiết cho việc điều tra sự cố.

Hệ thống đề xuất sẽ được triển khai và đánh giá trên bộ dữ liệu an ninh mạng chuẩn CICIDS2017. Các tiêu chí đánh giá sẽ được cấu trúc theo Khung Đánh giá 5 Chiều (5-Dimensional Evaluation Framework) toàn diện, bao quát Chỉ số Phân loại, Chỉ số Vận hành, Mức độ Kháng lỗi, Chất lượng Ngữ cảnh và Tính Giải thích.

Mục lục

Tóm tắt	1
1 Giới thiệu và Bối cảnh	3
1.1 Mô tả Vấn đề	3
1.2 Mục tiêu Nghiên cứu	3
1.3 Câu hỏi Nghiên cứu	4
1.4 Phạm vi Nghiên cứu	4
1.5 Cấu trúc Luận văn	4
2 Tổng quan Nghiên cứu	5
2.1 Các Phương pháp Nền tảng	5
2.2 Các Công trình Liên quan	5
3 Giải pháp Đề xuất và Phương pháp Nghiên cứu	7
3.1 Giải pháp Đề xuất: Kiến trúc Nhận thức Hai tầng	7
3.2 Công nghệ và Công cụ	8
4 Kế hoạch Triển khai và Đánh giá	9
4.1 Các Giai đoạn Phát triển Chính	9
4.2 Kế hoạch Đánh giá	9
5 Kết quả Kỳ vọng và Đóng góp Khoa học	11
5.1 Kết quả Kỳ vọng	11
5.2 Đóng góp Khoa học	11
6 Kết luận	12
Tài liệu tham khảo	13

1. Giới thiệu và Bối cảnh

1.1 Mô tả Vấn đề

Các Trung tâm Điều hành An ninh (SOC) hiện đại đang bị nhấn chìm bởi khối lượng sự kiện an ninh khổng lồ. Các báo cáo chuyên ngành gần đây chỉ ra rằng một phân tích viên SOC trung bình phải xử lý hàng nghìn cảnh báo mỗi ngày, trong đó gần một nửa bị xác định là dương tính giả [1]. Hiện tượng “quá tải cảnh báo” (alert fatigue) này trực tiếp dẫn đến việc các mối đe dọa nguy hiểm thực sự bị bỏ sót. Thêm vào đó, các hệ thống IDS/SIEM truyền thống thường phân tích từng nguồn dữ liệu (Web log, Firewall log) một cách rời rạc, làm giảm nghiêm trọng khả năng tương quan để phát hiện các chuỗi tấn công đa giai đoạn tinh vi.

Việc ứng dụng Mô hình Ngôn ngữ Lớn (LLM), đặc biệt là kiến trúc AI Tác tử (Agentic AI) và Retrieval-Augmented Generation (RAG), vào việc phân tích log tự động sinh ra những lỗ hổng chí mạng về cả vận hành lẫn bảo mật. Thứ nhất, độ trễ suy luận (reasoning latency) của hệ thống là quá cao đối với các môi trường luồng dữ liệu thời gian thực. Thứ hai, các kiến trúc Agentic AI mở rộng bề mặt tấn công (attack surface) vượt xa các LLM truyền thống. Các hệ thống tự trị này đặc biệt nhạy cảm với một phổ các véc-tơ tấn công tinh vi: các đòn *Indirect Prompt Injection* và *Jailbreaks* ẩn trong dữ liệu log [2], nơi kẻ tấn công chèn chỉ thị độc hại vào các trường động (ví dụ: User-Agent) nhằm thao túng logic của Agent. Hơn nữa, việc cấp quyền thực thi cho Agent tạo ra rủi ro *Thoát hộp cát* (*Sandbox Escape*) và *Thực thi mã từ xa* (*RCE*), trong khi việc hiển thị đầu ra của LLM trên bảng điều khiển mở ra lỗ hổng *Rò rỉ dữ liệu* (*Data Exfiltration*) thông qua render Markdown độc hại. Thêm vào đó, sự phụ thuộc vào cơ sở tri thức bên ngoài đặt hệ thống trước nguy cơ *Đầu độc tri thức* (*RAG Poisoning*), nơi kẻ xấu thay đổi tài liệu tham chiếu để bóp méo nhận thức ngữ cảnh của Agent. Điều này tạo ra một nghịch lý lớn: phân tích viên bắt buộc phải cấp cho Agent ngữ cảnh động và khả năng thực thi để điều tra các cuộc tấn công, nhưng việc này lại mở ra nguy cơ toàn bộ cơ sở hạ tầng SOC bị chiếm quyền điều khiển.

1.2 Mục tiêu Nghiên cứu

Nhận thấy những hạn chế trên, nghiên cứu này đặt mục tiêu phát triển một AI Security Agent tự trị dựa trên kiến trúc nhận thức hai tầng (cognitive two-tier architecture). Thay vì hoàn toàn phụ thuộc vào một LLM duy nhất để xử lý mọi log, luận văn đề xuất một cách tiếp cận lai: một động cơ quy tắc tốc độ cao kết hợp với một LLM Agent có khả năng suy luận sâu. Hướng tiếp cận này được kỳ vọng sẽ tối ưu hóa độ trễ suy luận bằng cách lọc nhiễu, giảm thiểu nguy cơ prompt injection qua cơ chế đóng gói có ranh giới, và nâng cao khả năng nhận

thức ngữ cảnh thông qua Bộ nhớ Rủi ro Dài hạn (Long-Term Threat Memory) và kiến trúc Dual-RAG. Một bảng điều khiển (Dashboard) kết hợp yếu tố Human-in-the-Loop (HITL) cũng sẽ được xây dựng để chứng minh tính thực tiễn của tự động hóa SOC.

1.3 Câu hỏi Nghiên cứu

Dựa trên các mục tiêu đã đề ra, luận văn tập trung giải quyết bốn câu hỏi nghiên cứu cốt lõi: 1. Việc áp dụng Kiến trúc Hai tầng (Rule-based + LLM Agent) kết hợp với Cơ sở Hành vi theo Phiên (Session-Aware Behavioral Baseline) có tối ưu hóa Độ trễ Suy luận so với phương pháp Một tầng (chỉ dùng LLM) hay không? 2. Liệu cơ chế Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation) có thể ngăn chặn hiệu quả các đòn Prompt Injection mang tính cấu trúc (ví dụ: Delimiter Smuggling) mà không làm suy giảm độ chính xác phân loại của LLM? 3. Kiến trúc Dual-RAG (kết hợp khung chuẩn chiến thuật và kiểm soát phòng thủ) cải thiện Độ phù hợp Ngữ cảnh (Context Relevance) của quá trình phân tích rủi ro do LLM thực hiện như thế nào? 4. Một vòng lặp phản hồi (Feedback Loop) mang tính thích ứng với cơ chế Cách ly HITL (HITL Quarantine) có thể ngăn chặn Adversarial Rule Injection và đảm bảo an toàn cho các phản ứng tự động ra sao?

1.4 Phạm vi Nghiên cứu

Nghiên cứu giới hạn trong phạm vi Phát hiện Xâm nhập Mạng (Network Intrusion Detection) và phân loại log tại SOC. Các thành phần trong phạm vi bao gồm: Pipeline luồng dữ liệu (Redis), Động cơ Quy tắc Tier-1, LangGraph Agent với Dual-RAG, Cơ chế Guardrails (Nén dữ liệu và Phòng thủ Injection), cùng Dashboard Streamlit hỗ trợ HITL với Bộ nhớ SQLite. Nghiên cứu không bao gồm việc tinh chỉnh (fine-tuning) các Mô hình Nền tảng (Foundation Models), triển khai hạ tầng phần cứng vật lý lớn, hay chống lại các đòn tấn công từ chối dịch vụ (DDoS) thể tích ở Layer 3/4.

1.5 Cấu trúc Luận văn

Luận văn được tổ chức thành sáu chương chính: (1) Giới thiệu và Bối cảnh; (2) Tổng quan Nghiên cứu; (3) Giải pháp Đề xuất và Phương pháp Nghiên cứu; (4) Kế hoạch Triển khai và Đánh giá; (5) Kết quả Kỳ vọng và Đóng góp Khoa học; và (6) Kết luận.

2. Tổng quan Nghiên cứu

2.1 Các Phương pháp Nền tảng

Trong giai đoạn đầu của lĩnh vực an ninh mạng, các Hệ thống Phát hiện Xâm nhập (IDS) chủ yếu dựa vào cơ chế đối sánh chữ ký (signature-based) để xác định các mối đe dọa đã biết. Mặc dù các hệ thống này mang lại hiệu suất cực cao về mặt thông lượng, chúng lại vấp phải những giới hạn nghiêm trọng trong việc nhận diện các đòn tấn công zero-day hoặc mã độc đa hình (polymorphic malware) [4].

Sự chuyển dịch sang Học máy (Machine Learning) đã mở ra kỷ nguyên của IDS dựa trên sự bất thường (anomaly-based), nơi các mô hình học cách phân biệt hành vi mạng bình thường và đánh dấu những sai lệch. Tuy vậy, do bản chất của lưu lượng mạng lành tính thường xuyên thay đổi, các phương pháp này thường tạo ra tỷ lệ dương tính giả rất cao. Các hệ thống SIEM hiện đại ra đời để gom nhóm và tương quan log, song chúng vẫn đòi hỏi sức lực khổng lồ từ con người để chấp vá ngữ cảnh của một cuộc tấn công.

2.2 Các Công trình Liên quan

Sự bùng nổ của các Mô hình Ngôn ngữ Lớn (LLM) gần đây đã chỉ ra hướng đi mới trong việc tự động tóm tắt log và phản ứng sự cố. Thay vì dịch nguyên văn các nghiên cứu trước, có thể tổng hợp rằng: nhiều bài khảo sát toàn diện [3] và các nghiên cứu điển hình [5] đã tận dụng các API đám mây mạnh mẽ để tự động hóa một phần công việc của SOC. Tuy nhiên, rào cản lớn nhất của hướng đi này là sự vi phạm nguyên tắc bảo mật dữ liệu lõi của doanh nghiệp, cộng với độ trễ truyền tải mạng khiến việc ứng phó theo thời gian thực trở nên bất khả thi.

Liên quan đến việc tăng cường tri thức bằng RAG (Retrieval-Augmented Generation) cho an ninh mạng, các nỗ lực tự động hóa ánh xạ chiến thuật tấn công vào biểu đồ tri thức đã mang lại kết quả khả quan [6]. Dù vậy, các nghiên cứu này phần lớn chỉ tập trung vào phân tích chiến thuật (tactical analysis) thuần túy mà bỏ qua việc liên kết với các tiêu chuẩn tuân thủ phòng thủ (như ISO 27001), dẫn đến việc hệ thống có thể phát hiện lỗi nhưng không đưa ra được hướng khắc phục thực tiễn.

Về vấn đề an toàn và tính kháng lỗi của bản thân LLM, danh sách OWASP Top 10 dành cho ứng dụng LLM [9] cùng các đánh giá chuyên sâu từ Agent Security Bench (ASB) [7] đã cảnh báo mức độ dễ tổn thương đáng báo động của các LLM Agent trước rủi ro prompt injection. Dù các thuật toán như Drain3 [8] rất phổ biến trong việc gom nhóm và nén log, chúng chủ yếu phục vụ mục đích lưu trữ chứ không mang thiết kế của một rào chắn an ninh

chủ động. Hơn nữa, các phương pháp luận đánh giá LLM gần đây nhấn mạnh sự cần thiết phải giải quyết Thiên kiến Tự đề cao (Self-Enhancement Bias) bằng cách sử dụng các mô hình đánh giá chéo họ (cross-family evaluation) hoặc các phép kiểm định thống kê thay vì chỉ dựa vào mô hình LLM-as-a-Judge đơn lẻ [10, 11]. Bức tranh học thuật hiện tại cho thấy sự thiếu vắng của một kiến trúc thống nhất, có khả năng tự phòng vệ với quy trình đánh giá nghiêm ngặt, từ đó khẳng định tính cấp thiết và định hướng nghiên cứu của luận văn này.

3. Giải pháp Đề xuất và Phương pháp Nghiên cứu

3.1 Giải pháp Đề xuất: Kiến trúc Nhận thức Hai tầng

Giải pháp đề xuất dựa trên một Kiến trúc Nhận thức Hai tầng (Cognitive Two-Tier Architecture) được thiết kế với nguyên tắc Phân tách Mối quan tâm (Separation of Concerns) nghiêm ngặt. Cốt lõi của giải pháp là kết hợp tốc độ xử lý của các bộ quy tắc xác định (Tier 1) với năng lực suy luận sâu sắc của LLM Tác tử (Tier 2), được kết nối với nhau bởi các lớp rào chắn (guardrails) chống tấn công adversarial mạnh mẽ.

Tại tầng đầu tiên (Tier 1), Động cơ Quy tắc đóng vai trò như một màng lọc heuristic tốc độ cao. Nó duy trì các đường cơ sở (baselines) hành vi nhận thức theo phiên bằng cách sử dụng cấu trúc dữ liệu trên bộ nhớ (như Redis) để theo dõi tần suất yêu cầu và các IP độc hại đã biết. Lớp này được thiết kế để loại bỏ tới 90% lưu lượng mạng thông thường hoặc các đợt tấn công thể tích (volumetric noise) ngay tại tốc độ đường truyền (wire speed).

Đối với những log có biểu hiện bất thường hoặc vượt qua ngưỡng mập mờ, chúng sẽ được chuyển đến Tầng Guardrail. Tại đây, quá trình vô hiệu hóa diễn ra theo hai bước tách biệt: 1. **Template Mining (Drain3)**: Trích xuất cấu trúc tĩnh của log để nén số lượng token mà không làm thay đổi các biến payload động. 2. **Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation)**: Các trường payload động được bao bọc bên trong các dấu phân cách sinh ngẫu nhiên theo chuẩn mật mã học (ví dụ: <<RANDOM_HEX>>). Điều này ngăn chặn triệt để đòn tấn công Delimiter Smuggling, khiến kẻ thù không thể thoát khỏi ranh giới dữ liệu để thực thi Prompt Injection.

Sau khi vượt qua guardrail, dữ liệu log sạch sẽ tiến vào Tier 2, được quản lý bởi một Agent phát triển trên nền LangGraph. Agent này ứng dụng cơ chế Dual-RAG, tiến hành truy vấn cơ sở dữ liệu vector cục bộ chứa thông tin phân tích từ MITRE ATT&CK và các biện pháp kiểm soát của ISO 27001. LLM sẽ tổng hợp lượng tri thức này để đưa ra kết luận về tính chất độc hại của sự kiện.

Cuối cùng, nhằm bảo vệ hệ thống trước đòn Adversarial Rule Injection, LLM không được phép trực tiếp thay đổi tường lửa ở Tier 1. Thay vào đó, các quy tắc do nó đề xuất sẽ bị đưa vào trạng thái Cách ly (Quarantine). Một quản trị viên SOC sẽ tiến hành rà soát các quy tắc này thông qua Dashboard (yếu tố Human-in-the-Loop) trước khi chúng được nạp nóng (hot-reload) vào hệ thống phòng thủ.

3.2 Công nghệ và Công cụ

Hệ thống được xây dựng hoàn toàn trên các framework Python hiện đại. Quá trình xử lý luồng và theo dõi phiên ngắn hạn dựa vào Redis. Động cơ suy luận LLM sử dụng các mô hình cục bộ đã được lượng tử hóa (ví dụ: Gemma-2-9B-IT) và phục vụ thông qua API của Oobabooga text-generation-webui nhằm đảm bảo quyền riêng tư dữ liệu tuyệt đối.

Luồng công việc của Agent được điều phối bởi LangGraph. Đối với phần truy xuất tri thức, thư viện `sentence-transformers` kết hợp với FAISS được sử dụng để tìm kiếm vector ngữ nghĩa tốc độ cao. Giao diện người dùng và bảng điều khiển HITL được phát triển bằng Streamlit, trong khi bộ nhớ rủi ro dài hạn và nhật ký kiểm toán (audit trails) được lưu trữ bền vững qua SQLite.

4. Kế hoạch Triển khai và Đánh giá

4.1 Các Giai đoạn Phát triển Chính

Giai đoạn đầu tiên của quá trình triển khai sẽ tập trung vào Pipeline Tiếp nhận Dữ liệu và Động cơ Quy tắc Tier 1. Bộ dữ liệu an ninh mạng tiêu chuẩn CICIDS2017 sẽ được tiền xử lý và mô phỏng thành luồng streaming thực tế. Cơ chế theo dõi phiên sẽ được xây dựng dựa trên chức năng TTL của Redis để thiết lập các đường cơ sở hành vi.

Tiếp theo đó, Tầng Guardrail sẽ được tích hợp. Thuật toán Drain3 sẽ được áp dụng cho mục đích template mining, đi kèm với việc phát triển module Đóng gói Dữ liệu mật mã học nhằm vô hiệu hóa các payload chứa mã độc adversarial.

Giai đoạn then chốt thứ ba là việc kiến tạo Agent ở Tier 2 sử dụng LangGraph và kho tri thức Dual-RAG. Hệ thống FAISS index sẽ được nạp dữ liệu từ các tiêu chuẩn MITRE và ISO. Quá trình thiết kế prompt cho Agent sẽ được căn chỉnh tinh tế để tách biệt hoàn toàn các chỉ thị hệ thống (system instructions) khỏi phần dữ liệu payload đã được đóng gói.

Giai đoạn cuối cùng là việc tích hợp Bảng điều khiển Streamlit và Bộ nhớ Dài hạn bằng SQLite. Bước này hoàn thiện chu trình khép kín của hệ thống bằng cách kích hoạt tính năng Human-in-the-Loop, cho phép quản trị viên phê duyệt các bộ quy tắc tự động do LLM sinh ra và đẩy ngược chúng trở lại Tier 1.

4.2 Kế hoạch Đánh giá

Nhằm kiểm chứng tính hiệu quả của hệ thống, nghiên cứu áp dụng chiến lược đánh giá toàn diện dựa trên Khung Đánh giá 5 Chiều (5-Dimensional Evaluation Framework).

Để đánh giá mức cơ sở, một Thí nghiệm Loại bỏ (Ablation Study) sẽ được tiến hành. Quá trình này so sánh hệ thống Hai tầng hoàn chỉnh với một kiến trúc chỉ sử dụng LLM đơn thuần để quan sát sự khác biệt về hiệu năng. Các tiêu chí đánh giá bao gồm:

- **1. Phân loại (Classification):** Điểm F1-Score, Precision, Recall và Tỷ lệ Dương tính giả (FPR), được phân tích ý nghĩa thống kê bằng kiểm định McNemar ($p < 0.05$).
- **2. Vận hành (Operational):** Độ trễ Xử lý (đại diện cho Thời gian Phát hiện/Phản hồi Trung bình), Tỷ lệ Leo thang HITL (Escalation Rate), và Tỷ lệ Cache Hit Ngữ nghĩa RAG, được kiểm định thông qua phép thử Mann-Whitney U ($p < 0.05$).
- **3. Kháng lỗi (Robustness):** Tỷ lệ Đánh bại Guardrail sẽ được kiểm thử bằng 45 mẫu adversarial đặc chế, bao trùm tấn công cấu trúc (Delimiter Smuggling) và nhầm lẫn ngữ nghĩa (Semantic Confusion).

- **4. Chất lượng Ngữ cảnh (Context Quality):** Sử dụng phương pháp tiếp cận LLM-as-a-Judge (lấy cảm hứng từ RAGAS) để chấm điểm Độ chính xác Ngữ cảnh, Sự liên quan của Câu trả lời, Tính trung thực (Faithfulness) và Độ bao phủ Ngữ cảnh (Context Recall).
- **5. Tính Giải thích (Explainability):** Tỷ lệ Hoàn thiện Nhật ký Kiểm toán (Audit Trail Completeness Rate) được đo lường một cách xác định (deterministic) thông qua kiểm tra tự động sự tồn tại của các trường dữ liệu.

5. Kết quả Kỳ vọng và Đóng góp Khoa học

5.1 Kết quả Kỳ vọng

Nghiên cứu này được kỳ vọng sẽ phát triển thành công một hệ thống tự trị hoàn chỉnh, có khả năng vận hành trơn tru toàn bộ chu trình xử lý của SOC — từ việc tiếp nhận log, lọc rác bằng thuật toán heuristic, thanh lọc mã độc adversarial, suy luận chuyên sâu, cho đến sinh quy tắc phòng thủ tự động.

Dưới góc độ kỹ thuật, kiến trúc Hai tầng được dự đoán sẽ giảm thiểu đáng kể độ trễ xử lý tổng thể so với các hệ thống chỉ dựa vào LLM, bởi lẽ Động cơ Tier 1 đã loại trừ hầu hết lưu lượng mạng lành tính. Việc áp dụng cơ chế Đóng gói Dữ liệu có Phân cách được kỳ vọng sẽ đạt tỷ lệ đánh chặn tuyệt đối trước các đòn tấn công prompt injection dạng cấu trúc, chứng minh khả năng tự phòng vệ vững chắc mà không tước đi phần dữ liệu payload quan trọng cần thiết cho việc điều tra của LLM.

Bên cạnh đó, quá trình tích hợp Dual-RAG hứa hẹn sẽ mang lại điểm số cao về Sự liên quan của Câu trả lời và Tính trung thực, đảm bảo rằng Agent luôn đưa ra các đề xuất khắc phục bám sát tiêu chuẩn tuân thủ thực tế thay vì sinh ra những kết quả ảo giác (hallucination).

5.2 Đóng góp Khoa học

Xét về mặt học thuật, đóng góp tiên quyết của nghiên cứu là việc đề xuất một Kiến trúc Nhận thức Hai tầng độc đáo, nối liền một cách an toàn giữa sức mạnh của Động cơ Quy tắc xác định với trí tuệ của LLM Agent. Hướng tiếp cận này vẫn còn rất mới mẻ trong các văn bản nghiên cứu an ninh mạng, đặc biệt là khi kết hợp việc triển khai các LLM bảo mật cục bộ cùng với rào chắn adversarial linh hoạt.

Đóng góp thứ hai nằm ở việc xây dựng phương pháp luận đánh giá các hệ thống SOC Agent dựa trên LLM. Thông qua Khung Đánh giá 5 Chiều (5D) — kết hợp giữa phân loại thống kê, chỉ số vận hành, kháng lỗi adversarial, chấm điểm LLM-as-a-Judge và tính giải thích — nghiên cứu cung cấp một chuẩn mực (baseline) toàn diện để các nghiên cứu tương lai về an ninh mạng AI có thể tham chiếu.

Cuối cùng, ở góc độ thực tiễn, nghiên cứu đóng góp một pipeline mã nguồn mở chuẩn hóa (SENTINEL), tích hợp toàn vẹn từ khâu phân loại cảnh báo đến sự phản hồi có giám sát của con người. Đây là một bộ khung có tính mở rộng cao, sẵn sàng để các tổ chức ứng dụng vào môi trường thực tế nhằm giảm thiểu vấn nạn quá tải cảnh báo một cách an toàn và bền vững.

6. Kết luận

Trong nghiên cứu này, chúng tôi đề xuất một Kiến trúc Nhận thức Hai tầng kết hợp một Động cơ Quy tắc xác định tốc độ cao với một Mô hình Ngôn ngữ Lớn Tác tử có khả năng suy luận sâu. Kiến trúc này được thiết kế để giải quyết "Nghịch lý Dữ liệu lớn" và hiện tượng quá tải cảnh báo đang bào mòn năng lực của các Trung tâm Điều hành An ninh hiện đại, đồng thời giảm thiểu các lỗ hổng rủi ro đặc thù khi ứng dụng trực tiếp LLM vào luồng dữ liệu adversarial log.

Hệ thống tận dụng tốc độ của Tier 1 để sàng lọc khối lượng lớn nhiễu, và tin cậy vào các rào chắn Guardrail vững chắc — cụ thể là cơ chế Đóng gói Dữ liệu có Phân cách — để trung hòa các đòn prompt injection trước khi chúng chạm đến Agent ở Tier 2. Được trang bị bộ nhớ tri thức Dual-RAG từ MITRE ATT&CK và ISO 27001, Agent có khả năng đưa ra các phân tích rủi ro giàu tính ngữ cảnh và có độ chính xác cao. Hơn thế nữa, thiết kế chu trình khép kín đảm bảo sự an toàn thông qua hệ thống cách ly Human-in-the-Loop.

Những đóng góp kỳ vọng của nghiên cứu bao gồm việc đề xuất kiến trúc hybrid mới lạ, cung cấp các phương pháp đánh giá thực nghiệm cho AI Security Agent, và phát triển một pipeline thực tiễn, mở rộng được cho quy trình phản ứng sự cố tự động theo thời gian thực. Các hướng nghiên cứu trong tương lai có thể hướng tới việc điều phối hệ thống đa tác tử (multi-agent orchestration) trên các tô-pô mạng phân tán hoặc tích hợp năng lực phân tích log đa phương thức (multi-modal).

Tài liệu

- [1] Ponemon Institute, “The State of Security Operations: Alert Fatigue and Analyst Burnout,” *Annual Cybersecurity Report*, 2023.
- [2] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [3] M. Habibzadeh, et al., “Large Language Models for Security Operations Centers: A Comprehensive Survey,” *arXiv preprint*, 2025.
- [4] A. Khraisat, I. Gondal, P. Vamplew, and J. Kamruzzaman, “Survey of intrusion detection systems: techniques, datasets and challenges,” *Cybersecurity*, vol. 2, no. 1, p. 20, 2019.
- [5] E. Oniagbi, et al., “LLMs in the SOC: Automated Log Analysis and Incident Response,” *Journal of Cybersecurity and AI*, 2024.
- [6] Research Group, “RAG-ATT&CK: Utilizing Knowledge Graphs for Threat Intelligence,” *Proceedings of the International Conference on Cyber Security*, 2024.
- [7] Y. Zhang, et al., “Agent Security Bench (ASB): Evaluating the Robustness of LLM Agents,” *arXiv preprint arXiv:2403.00000*, 2024.
- [8] P. He, J. Zhu, Z. Zheng, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *2017 IEEE International Conference on Web Services (ICWS)*, 2017.
- [9] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” *OWASP*, 2025.
- [10] S. Shahul Es, et al., “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [11] L. Zheng, W.-L. Chiang, et al., “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Proceedings of the 37th International Conference on Neural Information Processing Systems (NeurIPS)*, 2023.